Lab 23 — Multi-Factor Authentication with TOTP

You will add a "something you have" factor (TOTP) on top of SSH password / key auth using Google Authenticator's open-source PAM module.

Run on https://killercoda.com/playgrounds/scenario/ubuntu

Required software (free, apt): - `libpam-google-authenticator` - `qrencode` (optional, for QR display)

Step 1 — Install

```
apt update && apt install -y libpam-google-authenticator qrencode
```

Step 2 — Enrol a user

```
useradd -m mfauser && echo 'mfauser:Lab1234!' | chpasswd
```

```
sudo -u mfauser google-authenticator -t -d -f -r 3 -R 30 -W -q -s /home/mfauser/.google_authenticator
```

```
cat /home/mfauser/.google_authenticator | head -2
```

Flags: - `-t` time-based - `-d` disallow reuse of the same code - `-r 3 -R 30` rate-limit 3 attempts / 30s - `-W` window of 1 (more secure than default 3)

Step 3 — Display the secret as a QR (scan with Google/Microsoft Authenticator)

```
SECRET=$(head -1 /home/mfauser/.google_authenticator)

qrencode -t ANSI "otpauth://totp/lab:mfauser?
secret=$SECRET&issuer=lab"
```

Step 4 — Wire MFA into SSH PAM

```
echo "auth required pam_google_authenticator.so" >> /etc/pam.d/sshd

sed -i
's/^#*ChallengeResponseAuthentication.*/ChallengeResponseAuthenticati
on yes/' /etc/ssh/sshd_config

sed -i
's/^#*KbdInteractiveAuthentication.*/KbdInteractiveAuthentication
yes/' /etc/ssh/sshd_config

sed -i 's/^#*UsePAM.*/UsePAM yes/' /etc/ssh/sshd_config
```

```
echo "AuthenticationMethods publickey,keyboard-interactive" >> /etc/ssh/sshd_config

systemctl restart ssh
```

This enforces **two factors**: SSH key (something you have) + TOTP (something you also have).

Step 5 — Generate a code from CLI to test

```
apt install -y oathtool

oathtool --totp -b "$SECRET"
```

Use the 6-digit output to log in via SSH from another shell.

Step 6 — Discuss the AAA factor catalogue

Factor	Examples
Something you know	Password, PIN, secret question
Something you have	TOTP app, FIDO2 key, smart card
Something you are	Fingerprint, face, voice

Factor	Examples
Somewhere you are	Geo-IP, GPS
Something you do	Typing rhythm, swipe patterns

True MFA combines factors from **different** rows.

Free online tools

- **Google Authenticator** — Android/iOS
- **Microsoft Authenticator** — https://www.microsoft.com/security/mobile-authenticator-app
- **FreeOTP (open source)** — https://freeotp.github.io
- **Aegis Authenticator** — https://getaegis.app
- **YubiKey developer hub** — https://developers.yubico.com
- **WebAuthn.io demo** — https://webauthn.io

What you learned

- How PAM modules stack to add MFA without modifying sshd source.
- Why TOTP is "something you have" even though it looks like a password.
- That `AuthenticationMethods` enforces real two-factor (not 1-or-2).